Agente Supervisor de Consentimientos

AGT-CONSENT-01 — Resumen técnico y de funcionamiento

Auditoría de Sistemas · Grupo C · UNSA · Octubre 2026

1. ¿Qué es el agente?

El **Agente Supervisor de Consentimientos (AGT-CONSENT-01)** es un agente de Inteligencia Artificial que audita automáticamente si una organización gestiona correctamente el **consentimiento** de las personas sobre sus datos personales: cómo lo obtiene, cómo lo registra y cómo permite modificarlo o retirarlo.

Evalúa evidencias documentales (formularios web, políticas o avisos de privacidad y registros operativos) frente a dos marcos normativos:

- **ISO/IEC 27701:2025** (sistema de gestión de la privacidad): controles A.1.2.2, A.1.2.4, A.1.2.5, A.1.3.3, A.1.3.4 y A.1.3.5.
- **Ley N.° 29733**, Ley de Protección de Datos Personales del Perú: Artículos 5, 13.5, 14 y 18.

Su resultado es un **informe de auditoría** con un dictamen por dominio (Conforme, No Conforme o No Aplica), la norma aplicada, la cita textual de la evidencia, el hallazgo técnico y las medidas correctivas priorizadas.

1.1 Problema que resuelve

Verificar manualmente políticas, formularios y registros frente a la ISO y a la ley es lento y propenso a errores y omisiones. Un modelo de lenguaje por sí solo tampoco sirve, porque puede **alucinar** normas o hechos. El agente combina recuperación de la norma exacta (RAG), reglas verificables y un modelo de lenguaje local, y deja la última palabra a un auditor humano cuando hay dudas.

2. Cómo funciona, paso a paso

Cada evidencia recorre el siguiente flujo:

1. **Ingesta de la evidencia.** Se lee el archivo de texto, se calcula su huella SHA-256 (integridad) y se identifica la empresa y el alcance.
2. **Paso Fail-Fast (Art. 14, Ley N.° 29733).** Antes de evaluar cualquier control, el agente verifica si el caso encaja en una excepción legal donde **no se requiere consentimiento** (por ejemplo, la ejecución de un contrato o la prevención de lavado de activos). Si aplica, los dominios de obtención y revocación del consentimiento se dictaminan «No Aplica». Una excepción nunca ampara publicidad, marketing ni perfilamiento. Esto evita no conformidades falsas.
3. **Recuperación híbrida de la norma (RAG).** Para cada dominio se buscan los controles y artículos pertinentes combinando búsqueda por significado y por palabras exactas (detalle en la sección 4).
4. **Análisis de la evidencia con reglas.** Un motor determinista detecta casillas premarcadas, consentimientos agrupados, finalidades genéricas, falta de registro con fecha y hora, revocación solo por teléfono, entre otros. Reconoce negaciones («No se indican destinatarios…»).
5. **Razonamiento del LLM local** (llama3 vía Ollama, temperatura 0.0). Sigue la Cadena de Pensamiento del TIF: (1) exigencia normativa, (2) cita textual de la evidencia, (3) brecha, (4) veredicto. Responde en JSON con esquema fijo.
6. **Guardas anti-alucinación.** Se verifica que cada cita exista en la evidencia y que cada norma citada haya sido realmente recuperada. Si el LLM contradice a las reglas, se mantiene el dictamen de las reglas y se adjunta la opinión del LLM.

7. **Revisión humana (HITL).** Si hay observaciones, el informe queda «PENDIENTE_REVISION_AUDITOR»; si no, se emite y se registra en la bitácora de gobernanza.
8. **Generación de entregables.** Informe Markdown con la tabla del TIF, JSON estandarizado, CSV, Excel y matriz de evidencias.

2.1 Dominios evaluados

Dominio	Qué verifica	Norma
1. Deber de información y propósito	Finalidad específica (no genérica), destinatarios, plazo de conservación, identidad del responsable y canal para ejercer derechos.	ISO A.1.2.2, A.1.3.3, A.1.3.4 · Ley Art. 18
2. Obtención y registro del consentimiento	Consentimiento expreso, casilla no premarcada, no agrupado con términos, registro con fecha, hora y titular.	ISO A.1.2.4, A.1.2.5 · Ley Arts. 5 y 13.5
3. Modificación y revocación	Mecanismo para retirar el consentimiento, por el mismo canal en que se obtuvo, con plazo de respuesta.	ISO A.1.3.5 · Ley Art. 5
4. Excepciones legales	Resultado del paso Fail-Fast.	Ley Art. 14

3. Corpus normativo y fragmentación

La base de conocimiento está fragmentada con **chunking estructural**, tal como propone el TIF: la unidad mínima es el **artículo** de la ley (el Art. 14 se divide numeral por numeral, anteponiendo la cabecera del artículo) y el **control** de la ISO (Anexo A = requisito; Anexo B = guía). Cada fragmento lleva metadatos que permiten filtrar y citar:

Campo	Uso	Ejemplo
norma	Instrumento de origen	ISO/IEC 27701:2025; Ley N.° 29733
control / articulo / numeral	Identificador exacto	A.1.2.5 · Art. 14, numeral 5
seccion_jerarquica	Ruta dentro del documento	Anexo A > Tabla A.1 > A.1.2.5
naturaleza	Rol en el razonamiento (habilita el Fail-Fast)	requisito_normativo; guia; excepcion
tipo_texto	Si es literal o resumen	resumen

Por derechos de autor de la ISO, el corpus base (config/corpus_normativo.json) contiene **resúmenes redactados por el equipo**. Si se agregan los PDF oficiales con texto en la carpeta documentos_normativos/, el agente los fragmenta y los incorpora con texto literal.

4. Búsqueda híbrida (RAG)

La recuperación tiene tres etapas, como en el TIF (sección 3.5):

- **Búsqueda densa:** embeddings multilingües (paraphrase-multilingual-MiniLM-L12-v2) que encuentran fragmentos parecidos en significado aunque no compartan palabras.

- **Búsqueda dispersa (BM25):** coincidencias exactas de términos jurídicos («Art. 14», «A.1.3.5», «revocar»).
- **Fusión RRF + Cross-Encoder:** las dos listas se combinan con Reciprocal Rank Fusion y un Cross-Encoder multilingüe (bge-reranker-v2-m3) reordena los candidatos; solo los mejores llegan al LLM.

Además se aplican **filtros de metadatos** según el paso: el Fail-Fast solo consulta fragmentos con artículo 14 y naturaleza «excepción»; cada dominio filtra por sus controles y artículos. La base vectorial es **Qdrant**, que funciona embebida en una carpeta del proyecto (sin Docker). Existe también un modo «local» (BM25 en Python puro) que funciona sin ninguna instalación adicional.

5. Controles de calidad y revisión humana

El informe **no se emite automáticamente** y pasa a la cola del auditor cuando:

- se aplicó una excepción del Art. 14 (dictamen de inaplicabilidad);
- se detectan instrucciones maliciosas escondidas en la evidencia (prompt injection);
- el LLM cita texto que no está en la evidencia o normas que no se recuperaron;
- el LLM discrepa del dictamen de las reglas o reporta una confianza muy baja.

El auditor aprueba o rechaza cada ticket; los informes aprobados se consolidan en informes_finales.json y en la bitácora de gobernanza.

6. Estructura del proyecto

Se organizó con la misma estructura que el agente Data Bridge (AGT-DATA-INV-01) del grupo:

Componente	Función
agente/agent.py	Orquestador: Fail-Fast, dominios, guardas e informe estandarizado.
agente/corpus.py	Chunking estructural y metadatos.
agente/retrieval.py	Búsqueda local (BM25) y Qdrant híbrido (densa + BM25 → RRF → Cross-Encoder).
agente/evidence.py	Reglas sobre la evidencia, negaciones, inyección y catálogo del Art. 14.
agente/reasoner.py	Cliente de Ollama con salida JSON (4 pasos de la Cadena de Pensamiento).
agente/hitl.py	Cola de revisión del auditor y bitácora de gobernanza.
agente/exporters.py	Informe Markdown, JSON, CSV, Excel y matriz de evidencias.
config/	corpus_normativo.json, consent_rules.json, excepciones_art14.json.
mcp_server.py	Servidor MCP con 5 herramientas (recuperar normas, Fail-Fast, analizar evidencia, emitir informe, auditoría completa).
.opencode/	Definición del agente y del skill para opencode.
run_demo.py / rag_auditor.py	Demo de todos los casos / auditoría de un caso.
tests/	16 pruebas automáticas con pytest.

7. Resultados de la demostración

Ejecutado en el equipo del grupo con Qdrant embebido, Cross-Encoder y llama3 real:

Caso	Qué demuestra	Dictamen	Estado
TiendaAndina (caso del TIF)	Casilla premarcada, finalidad genérica, baja solo por teléfono, sin registro	No Conforme en los 3 dominios (coincide con la tabla 3.7 del TIF)	Emitido
Banco Andino	Excepción contractual (Art. 14, numeral 5)	Dominios 2 y 3 No Aplica; dominio 1 No Conforme	Revisión del auditor
LibreríaSur	Formulario bien diseñado	Conforme en los 3 dominios	Revisión (el LLM opinó distinto)
ClubFit	Instrucción maliciosa oculta en el formulario	No Conforme; ataque detectado	Revisión del auditor

Evaluación del LLM (4 decisiones de Fail-Fast + 6 dictámenes por dominio): llama3 acertó **8 de 10** y llama3.1 **6 de 10**. Los modelos de 8B tienden a dictaminar «No Conforme» en casos que cumplen; por ello el LLM actúa como segunda opinión y las reglas verificables, junto con el auditor, tienen la última palabra.

8. Cómo ejecutarlo

En PowerShell, desde la carpeta del proyecto (Ollama debe estar abierto):

```
cd C:\Users\User\Desktop\Auditoria
.\.venv\Scripts\Activate.ps1
python run_demo.py --modo qdrant     # demo completa con LLM (~7 min)
python run_demo.py                   # demo rápida sin LLM (~2 s)
python rag_auditor.py --evidencia evidencias\caso_banco.txt
pytest -q                            # pruebas automáticas
```

Los resultados quedan en la carpeta out/: un informe Markdown por caso (informe_<caso>.md), informes_draft.xlsx/.csv/.json, matriz_evidencias.json y la cola de revisión pending_reviews.json. Para auditar un caso nuevo basta con crear un archivo .txt en evidencias/.

9. Relación con el TIF

Propuesta del TIF	Estado en el agente
Corpus ISO 27701 + Ley 29733 (3.1)	Implementado (resúmenes; PDF literales opcionales)
Fail-Fast sobre el Art. 14 (3.2)	Implementado como paso real con filtro de metadatos
System Prompt restrictivo, temperatura 0.0, CoT de 4 pasos (3.3)	Implementado; los 4 pasos son campos obligatorios del JSON
Chunking estructural y metadatos (3.4)	Implementado
Densa + BM25 → RRF → Cross-Encoder (3.5)	Implementado (modo qdrant)

Propuesta del TIF	Estado en el agente
Reporte en 4 dominios (3.7)	Implementado; reproduce el caso TiendaAndina
Robustez ante instrucciones maliciosas (4.2.4)	Implementado (detección + HITL)
API, interfaz web (4.2.2, 4.2.3)	Parcial: servidor MCP; falta interfaz web

10. Limitaciones y trabajo pendiente

- Los textos de la ISO en el corpus son resúmenes; el PDF disponible de la ISO es escaneado y requiere OCR para usar su texto literal.
- Los numerales del Art. 14 y la redacción de la ley deben verificarse contra el texto oficial consolidado vigente.
- Los LLM locales de 8B no son jueces fiables por sí solos; se recomienda probar modelos mayores (por ejemplo qwen2.5:7b, ya descargado) y ampliar el conjunto de casos etiquetados.
- Pendiente: interfaz web y evaluación con casos reales etiquetados por un experto.